



IPSEC REGULATORY AUDIT & CRYPTOGRAPHIC HEALTH

IPsec VPN Security Assessment & Framework Audit

Comprehensive evaluation against NIST SP 800-77 Rev. 1, RFC 8221, and NSA CNSA 2.0 cryptographic mandates

100
GRADE A • COMPLIANT

CONDITIONAL COMPLIANCE • ATTENTION REQUIRED

The IPsec deployment scored 100.0 out of 100 (GRADE A : COMPLIANT), indicating robust transport confidentiality via AES-256-GCM encryption. However, critical gaps in Child SA forward secrecy and static shared key authentication require remediation under NIST SP 800-77 Rev 1.

Section 1: Scope & Regulatory Framework

Definition of audit benchmarks (NIST SP 800-77 Rev. 1, RFC 8221, NSA CNSA 2.0)

AUDIT SCOPE & TARGET GATEWAYS

Multi-Link IPsec Topology (3 Tunnels)

ASSESSMENT TIMEFRAME

Live Telemetry (FULL): +0.0s - +15.0s (15.0s)

REGULATORY BENCHMARK	TITLE & JURISDICTION	MANDATED CRYPTOGRAPHIC REQUIREMENTS	AUDIT COMPLIANCE VERDICT
	Guide to IPsec VPNs		CONDITIONAL GAP
	ESP and AH Cryptographic Requirements		COMPLIANT
	Commercial National Security Algorithm Suite		PARTIAL ALIGNMENT

Section 2: Cryptographic Health Audit

Granular evaluation of symmetric ciphers (AES-GCM vs. CBC/3DES) and hashing integrity (SHA-256 vs. SHA-1/MD5)

SYMMETRIC ENCRYPTION CIPHER

APPROVED

AES-256-GCM

Operating Mode: AEAD (Galois/Counter Mode)

Integrity Tag: 128-bit ICV Authentication Tag

Key Length: 256 bits

AEAD ciphers combine confidentiality and message integrity in a single pass, eliminating padding oracle vectors (POODLE).

HASHING & MESSAGE INTEGRITY

APPROVED

SHA-256 / HMAC-SHA2-256

Digest Size: 256 bits (SHA-256)

Collision Resistance: Verified (FIPS 180-4 Compliant)

Deprecated Primitives: MD5 / SHA-1 Not Detected

Collision-resistant cryptographic hashing verified. No legacy SHA-1 or MD5 digests detected.



KEY MANAGEMENT, PROTOCOL & STATE INTEGRITY

Key Exchange & Protocol State Integrity

Diffie-Hellman modulus size verification, post-quantum posture, sequence rollover safeguards, and anti-replay integrity

Section 3: Key Management & Exchange Audit

Verification of Diffie-Hellman modulus size, post-quantum posture, and PFS rekey enforcement

DIFFIE-HELLMAN MODULUS STRENGTH APPROVED ECP-256 / MODP-1024 256-bit Elliptic Curve (~3072-bit RSA equivalent) Meets NIST SP 800-57 Part 1 Rev 5 discrete logarithm strength recommendations.	PERFECT FORWARD SECRECY (PFS) REKEY CRITICAL NON-COMPLIANCE Disabled (Re-uses IKE Master Secret) IKE SA: Active (DH Group 19) -11 pts Absence of ephemeral DH exchange during Child SA rekey means compromise of long-term credentials enables retrospective bulk session decryption.
POST-QUANTUM CRYPTOGRAPHIC POSTURE TRANSITION MANDATED CLASSICAL ECC (Pre-Quantum) Target: Hybrid ML-KEM-768 (Kyber) + ECP-256 Migrate to Hybrid ML-KEM-768 (Kyber) + ECP-256 per NSA CNSA 2.0 transition mandate (2026–2030).	SA ROTATION LIFETIMES & LIMITS ALIGNED 3600 seconds (1 Hour) 1,000 MB (1 GB Transfer Threshold) Strict rekey intervals constrain cryptanalytic exposure window under high packet volumes, adhering to RFC 7296 recommendations.

Section 4: Protocol & State Integrity

Anti-replay window sizing, sequence rollover safeguards, and IKE mode security (e.g., IKEv1 Aggressive Mode detection)

ANTI-REPLAY WINDOW SIZING ACTIVE & VERIFIED 64-bit sliding window (RFC 4303) Kernel IPsec state maintains strict packet sequence bitmap. Zero replay packet injection attempts observed.	SEQUENCE ROLLOVER SAFEGUARDS HARDENED 64-bit Extended Sequence Numbers (ESN) Protects against 2^{32} sequence cycling attacks under 100Gbps+ multi-core line-rate traffic. Safe for >500 years continuous transfer.	IKE MODE SECURITY & DOWNGRADE PROTECTED IKEv2 (RFC 7296) IKEv1 Aggressive Mode NOT detected. Unencrypted identity hashing is prevented, neutralizing offline dictionary cracking.
--	---	---



SIDE-CHANNEL AUDIT & METADATA VULNERABILITY REGISTER

Side-Channel & Metadata Vulnerability Audit

Traffic Flow Confidentiality (TFC) leakage, packet shape predictability, and side-channel exposure register

Section 5: Side-Channel & Metadata Vulnerability Audit

Leakage score based on packet shape predictability, burstiness, and missing Traffic Flow Confidentiality (TFC) padding

SIDE-CHANNEL LEAKAGE SCORE 74 MODERATE RISK Quantifies side-channel intelligence exposure based on unpadded packet length distributions and transmission cadences.	PACKET SHAPE PREDICTABILITY HIGH PREDICTABILITY Histogram analysis shows distinct clustering around 1420B (video stream) and 180B (audio codec). Clear application fingerprinting possible.	BURSTINESS & IAT TIMING MODERATE LEAKAGE Inter-arrival timing demonstrates regular 20ms frame intervals, leaking interactive VoIP/stream cadences.	TFC PADDING AUDIT MISSING / DISABLED (-3 pts) Activate Traffic Flow Confidentiality (TFC) padding per RFC 4303 §2.7 to mask packet size signatures.
--	--	---	--

METADATA LEAKAGE ASSESSMENT & TFC DEFENSE STRATEGY

While payload encryption via AES-256-GCM is mathematically unbreakable under current cryptanalytic standards, passive adversaries monitoring the wire can extract valuable behavioral intelligence without decrypting the payload. Packet arrival intervals, burst durations, and frame sizes correlate strongly with user activity, application types, and data transfer volumes. Enabling strongSwan Traffic Flow Confidentiality (`'esp_proposals = aes256gcm16-ecp256!'`, `'tfc = yes'`) and injecting dummy padding packets eliminates side-channel signatures.



COMPREHENSIVE THREAT MATRIX & REMEDIATION ROADMAP

Comprehensive Threat Matrix & Posture Projection

Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and post-remediation posture projection

Section 6: Comprehensive Threat & Vulnerability Matrix

Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and audit remediation mandates

VULN ID	VULNERABILITY & THREAT VECTOR	CVSS v3.1 BASE / ENV	SEVERITY	REMEDIATION MANDATE
AV-VULN-2026-001	Absence of Child SA Perfect Forward Secrecy	Base: 7.5 Env: 6.8	HIGH	NIST SP 800-77 Rev. 1 §4.2.3
AV-VULN-2026-002	Static Pre-Shared Key (PSK) Mutual Authentication	Base: 6.5 Env: 5.9	MEDIUM	RFC 8221 / Enterprise PKI Standard
AV-VULN-2026-003	Missing Traffic Flow Confidentiality (TFC) Padding	Base: 4.3 Env: 3.8	MEDIUM	RFC 4303 §2.7 Side-Channel Defense
AV-VULN-2026-004	Anti-Replay Window Verification	Base: 0 Env: 0	LOW	RFC 4303 §3.4.3 Anti-Replay

0
CRITICAL

2
MEDIUM

1
HIGH

1
LOW

PROJECTED POST-REMEDIATION POSTURE

CURRENT SCORE	PROJECTED GAIN	PROJECTED SCORE	PROJECTED GRADE
35 / 100	+19 pts	54 / 100	GRADE A+ - FULLY HARDENED

Executing the top two priority directives (enforcing PFS Diffie-Hellman Group 19 on Child SAs and migrating from PSK to X.509 enterprise PKI certificates) immediately eliminates 16 penalty points, elevating the IPsec deployment to complete NIST SP 800-77 Rev. 1 compliance.

OFFICIAL COMPLIANCE ACCREDITATION

This security evaluation was conducted according to the NIST SP 800-77 Rev. 1 and RFC 8221 security assessment methodologies. Cryptographic controls have been validated via deep deterministic state analysis.

ACCREDITATION STATUS

Classification: RESTRICTED
Framework: NIST SP 800-77 Rev. 1
Integrity: Cryptographically Signed